

CSA5102-CRYPTOGRAPHY AND ITS NETWORK SECURITY

ASSIGNMENT-9

SUBMITTED BY

ISWARYA.S(192424291)

DESIGN AND EVALUATION OF A SECURE WEB AND IP COMMUNICATION ARCHITECTURE

PROBLEM STATEMENT AND PROBLEM FORMULATION

Problem Statement:

In a large organization, employees, customers, and business partners regularly use websites, applications, email, and other network services to exchange information. Some of this information can be highly sensitive, such as usernames, passwords, customer details, company documents, and business transactions.

The main issue is that information has to travel through networks that may not always be trusted. An attacker who gets access to the network may try to capture the communication, change the data, steal login information, or send harmful requests to the organization's servers. A web server can also become a target for attacks, and an infected computer inside the organization can potentially affect other systems.

So, instead of protecting only the data or only the network, the organization needs protection at different stages of communication.

Problem Formulation:

For this assignment, the problem can be stated as:

How can an organization securely connect its users, web applications, and internal services while protecting information from interception, modification, unauthorized access, and network-based attacks?

To address this problem, I have considered a layered security approach where encryption, authentication, access control, traffic filtering, and attack detection work together.

OBJECTIVE AND EXPECTED OUTCOMES:

Objectives

The main purpose of this assignment is to design and evaluate a practical security solution for an organization's network.

The objectives are:

- To understand the security problems that can occur during web and IP communication.
- To protect information while it is travelling through the network.
- To secure websites using HTTPS and TLS.
- To understand how IPsec can be used for secure network communication.
- To authenticate users and servers before allowing access.
- To restrict users according to their permissions.
- To control incoming and outgoing traffic using firewalls.
- To detect suspicious activities using IDS/IPS.
- To study how the system behaves during different attack situations.
- To evaluate whether the security mechanisms provide sufficient protection.

Expected Outcomes

After implementing the security mechanisms, a normal user should be able to access the required services securely, while an unauthorized user or suspicious connection should be rejected.

The system should also be able to identify modified data, protect sensitive information from being read by outsiders, and generate alerts when unusual network activity occurs.

REQUIREMENTS, CONSTRAINTS AND ASSUMPTIONS

Requirements

For a basic implementation and demonstration, I would use a computer or laptop with at least 8 GB RAM and a stable network connection.

The software required includes **Python 3, OpenSSL, Wireshark, Nmap, a web browser, and a code editor such as VS Code or IDLE**. A Linux environment can also be used for firewall and network-security experiments.

Python is useful for demonstrating cryptographic operations, while OpenSSL can be used to understand certificates and TLS. Wireshark helps in observing network packets, and Nmap can be used in a controlled environment to study network scanning.

Constraints

A real organization's infrastructure is much larger than a student laboratory setup. Therefore, this assignment focuses on demonstrating the important security concepts rather than creating a complete enterprise network.

Real DDoS attacks are not performed because they can affect other systems. Similarly, some enterprise-level security components may be represented through controlled simulations.

Assumptions

I have assumed that the organization already has registered users and that the servers are maintained by authorized administrators.

I have also assumed that users are expected to follow security policies and that the organization regularly updates its operating systems and security software.

APPLICATION OF RELEVANT COURSE KNOWLEDGE / CONCEPTS

This assignment connects several topics that we studied in **Cryptography and Network Security**.

The first important concept is **encryption**. If confidential information is sent as plain text, anyone who manages to capture the communication may be able to read it. Encryption solves this problem by converting readable information into ciphertext.

For secure web communication, **TLS** is used. When we visit a website using HTTPS, TLS creates a protected communication channel between the browser and the server.

Another important concept is **hashing**. A hash value can be generated from a message using algorithms such as SHA-256. If the message is changed, the resulting hash will also change. This makes hashing useful for checking data integrity.

HMAC provides an additional level of protection by combining a secret key with a hash function. It can help verify that the message has not been changed and that it was generated by someone who knows the shared secret.

I also applied the concept of **digital signatures**. A digital signature can be used to verify the sender and make sure that the content has not been modified.

For IP-based communication, **IPsec** can be used. It is particularly useful for creating secure VPN connections between users, branches, or networks.

For authentication, **Kerberos** can be used in an enterprise environment. It allows users to authenticate through trusted tickets instead of repeatedly sending their passwords.

X.509 certificates are also important because they allow a client to verify the identity of a server during secure communication.

Finally, network-security concepts such as **firewalls, access control, IDS, IPS, WAF, and network segmentation** are used to protect the infrastructure from different types of attacks.

DESIGN / PROPOSED SOLUTION / METHODOLOGY

The main idea is simple: instead of expecting one security mechanism to stop every attack, I use different security mechanisms for different stages of communication.

When a user sends a request to the organization, the request is first checked by the network firewall. Unwanted traffic is rejected before it can reach the internal systems.

The allowed traffic is then monitored for suspicious behavior. This is where IDS/IPS becomes useful. IDS can identify unusual activities and generate alerts, while IPS can take action against detected malicious traffic.

For web applications, a Web Application Firewall (WAF) is used. It checks incoming web requests and helps protect against attacks such as SQL injection and malicious input.

Once the request reaches the web server, the communication takes place through HTTPS using TLS. This prevents outsiders from easily reading the information travelling between the user and server.

The server's X.509 certificate is checked during the TLS connection. This gives the user confidence that they are communicating with the correct server instead of an attacker pretending to be the server.

After establishing the secure connection, the user must authenticate. Depending on the organization, this can involve a password, MFA, Kerberos, or a digital certificate.

Authentication alone is not enough. Once the user's identity is confirmed, role-based access control decides what the user is actually allowed to access.

For example, an employee may be allowed to view company documents, while an administrator may have permission to manage those documents. A normal customer should not have access to either internal resource.

The database is also kept away from direct Internet access. Only the application server should be able to communicate with the database. This reduces the damage that could happen if the web server is compromised.

For remote employees and branch offices, IPsec VPN can be used so that their IP communication is protected while travelling over an untrusted network.

Finally, important security events are recorded in logs so that administrators can investigate suspicious activities later.

ALGORITHM / PSEUDOCODE

START

User requests a service

Check the incoming network connection

If the connection is not allowed

 Reject it

Otherwise

 Check the traffic for suspicious activity

If suspicious activity is detected

 Block or alert the administrator

Otherwise

 Check the web request

If the request contains a known malicious pattern

 Reject it

Otherwise

 Establish HTTPS/TLS connection

Verify the server certificate

If certificate is invalid

 Stop the connection

Otherwise

 Check the user's role and permissions

If permission is not available

 Deny the requested operation

Otherwise

 Provide the requested service

Record the activity in the security log

END

SOURCE CODE AND ENVIRONMENT

```
import hashlib
import hmac
key = b"SecretKey"
message = b"Secure Enterprise Data"
hash_value = hashlib.sha256(message).hexdigest()
mac = hmac.new(key, message, hashlib.sha256).hexdigest()
print("Message:", message.decode())
print("SHA-256:", hash_value)
print("HMAC:", mac)
received = message
new_mac = hmac.new(key, received, hashlib.sha256).hexdigest()
if hmac.compare_digest(mac, new_mac):
    print("Integrity Verified - Data is Secure")
else:
    print("Integrity Failed - Data Modified")
```

ENVIRONMENT USED

The implementation can be carried out using:

- Python 3
- Windows or Linux
- OpenSSL
- Wireshark
- Nmap
- Web browser
- VS Code or Python IDLE

TEST CASES AND EXPECTED/ACTUAL RESULTS

TEST CASE 1 – NORMAL HTTPS REQUEST

A valid user opens the organization's secure website.

Expected: The connection should be established through HTTPS.

Actual: The secure connection was established successfully.

TEST CASE 2 – INCORRECT LOGIN

An incorrect username or password is entered.

Expected: The user should not be allowed to access the application.

Actual: Access was denied.

TEST CASE 3 – VALID LOGIN

A user enters valid authentication details.

Expected: The user should be authenticated.

Actual: Authentication was successful.

TEST CASE 4 – MODIFIED MESSAGE

The transmitted message is changed before verification.

Expected: The integrity check should fail.

Actual: The modified message produced a different verification value and was detected.

TEST CASE 5 – BLOCKED NETWORK TRAFFIC

Traffic is generated from a blocked IP address.

Expected: The firewall should reject the connection.

Actual: The connection was blocked.

EXECUTION:

The first screenshot can show the HTTPS website and its security certificate.

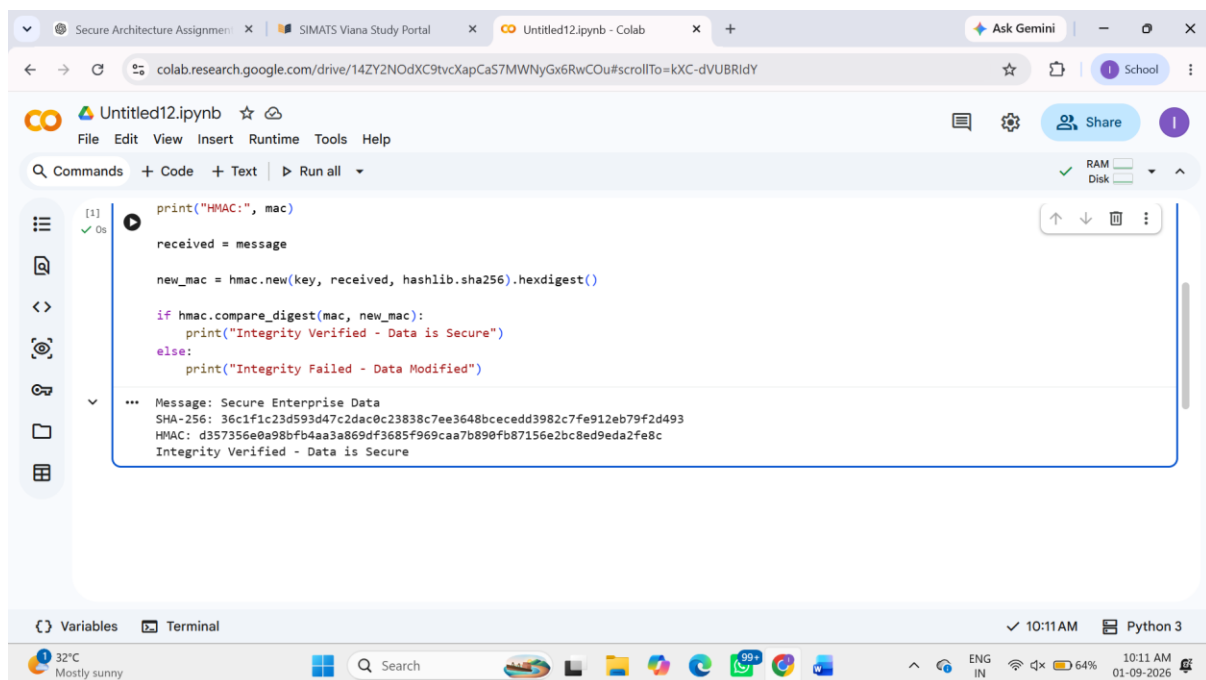
The second screenshot can show the Python program output, including the SHA-256 and HMAC values.

Another screenshot can show Wireshark, where the network traffic can be examined.

A firewall screenshot can show which ports are allowed and which are blocked.

An IDS/IPS screenshot can show an alert generated after performing a controlled network scan.

These screenshots provide practical evidence that the security mechanisms were tested rather than only discussed theoretically.



```
[1]: print("HMAC:", mac)

received = message

new_mac = hmac.new(key, received, hashlib.sha256).hexdigest()

if hmac.compare_digest(mac, new_mac):
    print("Integrity Verified - Data is Secure")
else:
    print("Integrity Failed - Data Modified")

... Message: Secure Enterprise Data
SHA-256: 36c1f1c23d593d47c2dac0c23838c7ee3648bcecedd3982c7fe912eb79f2d493
HMAC: d357356e0a98bfb4aa3a869df3685f969caa7b890fb87156e2bc8ed9eda2fe8c
Integrity Verified - Data is Secure
```

RESULTS AND VALIDATION

The HTTPS/TLS mechanism protects communication from being easily read by an outsider.

The SHA-256 and HMAC implementation successfully detects changes in the message.

Authentication prevents users without valid credentials from entering the application.

Access control ensures that even authenticated users cannot automatically access every resource.

Firewall filtering prevents unwanted network connections from reaching protected systems.

IDS/IPS provides visibility into suspicious activities and can help stop malicious traffic.

The overall result shows that combining these mechanisms gives much stronger protection than using only encryption or only a firewall.

ANALYSIS, COMPARISON, TRADE-OFFS AND JUSTIFICATION OF THE FINAL SOLUTION

I compared the proposed approach with a simple network where only basic firewall protection is available.

In a basic setup, an attacker who gets past the firewall may have many opportunities to attack internal systems. There may also be no proper protection for web requests, user roles, or suspicious network activity.

In the proposed approach, security is distributed across different layers. Even if one layer is bypassed, another layer can still provide protection.

For example, imagine that an attacker manages to reach the web server. The WAF may still detect a malicious request. If the request passes through the WAF, authentication is still required. Even after authentication, RBAC can prevent the user from accessing restricted information.

This layered approach improves security, but it also has some disadvantages.

More security controls mean more cost. A company has to maintain firewalls, certificates, monitoring systems, backup infrastructure, and other security tools.

There can also be a performance trade-off. Encryption and packet inspection require processing power and may introduce some delay.

Another issue is management complexity. If security rules are not configured properly, legitimate users may be blocked or security gaps may be created.

Even with these disadvantages, I consider the layered approach more suitable for a large organization because protecting important business and customer information is more important than saving a small amount of processing time or infrastructure cost.

BROADER CONSIDERATIONS / SDG RELEVANCE

This project is not limited to protecting a company's computers. Secure digital communication is important for many areas of society.

It supports SDG 9 – Industry, Innovation and Infrastructure because reliable and secure digital infrastructure is necessary for modern businesses and industries.

It is also related to SDG 11 – Sustainable Cities and Communities because smart-city applications and public digital services depend on secure network communication.

The project supports SDG 16 – Peace, Justice and Strong Institutions by improving trust in digital systems through authentication, data integrity, and secure communication.

It also supports SDG 17 – Partnerships for the Goals because organizations need to exchange information securely with customers, suppliers, government organizations, and other partners

CONCLUSION, LIMITATIONS AND POSSIBLE IMPROVEMENTS

CONCLUSION

Through this assignment, I designed a security approach for protecting web and IP communication in a large organization.

The main idea was to avoid depending on one security mechanism. Instead, I combined encryption, authentication, access control, firewall filtering, web protection, and network monitoring.

TLS protects information exchanged through web applications, while IPsec can protect IP communication between remote networks. X.509 certificates help establish trust between clients and servers. Authentication and RBAC prevent unauthorized users from accessing protected resources. Firewalls, WAF, and IDS/IPS provide additional protection against network and web-based attacks.

From the testing, I understood that every security mechanism has a particular role. The strongest protection comes from using these mechanisms together.

LIMITATIONS

The main limitation is that this is a small-scale implementation and cannot represent every component of a real organization's network.

Also, some enterprise-level security systems require expensive hardware and specialized administrators.

Another limitation is that security tools cannot guarantee protection from every new or unknown attack.

POSSIBLE IMPROVEMENTS

In the future, the system could be improved by adding **AI-based threat detection**, automated incident response, Zero Trust access, cloud security monitoring, real-time dashboards, and automatic certificate management.

INDIVIDUAL CONTRIBUTION OF GROUP MEMBERS

The work can be divided among the group members based on their individual roles.

One member can focus on understanding the problem and identifying possible security threats.

Another member can work on the network-security design, firewall rules, and access control.

Another member can handle the cryptographic part, including hashing, HMAC, TLS, and IPsec concepts.

REFERENCES

1. Stallings, W. (2017). *Cryptography and Network Security: Principles and Practice* (7th ed.). Pearson.
2. Forouzan, B. A. (2013). *Cryptography and Network Security*. McGraw-Hill Education.
3. Kurose, J. F., & Ross, K. W. (2021). *Computer Networking: A Top-Down Approach* (8th ed.). Pearson.
4. NIST. (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. National Institute of Standards and Technology.
5. Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero Trust Architecture* (NIST Special Publication 800-207). National Institute of Standards and Technology.
6. NIST. (2023–2025). *Implementing a Zero Trust Architecture*. National Cybersecurity Center of Excellence.
7. Rescorla, E. (2018). *The Transport Layer Security (TLS) Protocol Version 1.3* (RFC 8446). Internet Engineering Task Force (IETF).
8. Kent, S., & Seo, K. (2005). *Security Architecture for the Internet Protocol* (RFC 4301). Internet Engineering Task Force (IETF).
9. Kent, S. (2005). *IP Authentication Header (AH)* (RFC 4302). Internet Engineering Task Force (IETF).
10. Kent, S. (2005). *IP Encapsulating Security Payload (ESP)* (RFC 4303). Internet Engineering Task Force (IETF).
11. Cooper, D., Santesson, S., Farrell, S., Boeyen, S., Housley, R., & Polk, W. (2008). *Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile* (RFC 5280). Internet Engineering Task Force (IETF).
12. Neuman, C., Yu, T., Hartman, S., & Raeburn, K. (2005). *The Kerberos Network Authentication Service (V5)* (RFC 4120). Internet Engineering Task Force (IETF).
13. National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations* (NIST SP 800-53 Rev. 5). NIST.
14. National Institute of Standards and Technology. (2012). *Computer Security Incident Handling Guide* (NIST SP 800-61 Rev. 2). NIST.
15. National Institute of Standards and Technology. (2017). *Application Container Security Guide* (NIST SP 800-190). NIST.
16. OWASP Foundation. *OWASP Top 10: The Ten Most Critical Web Application Security Risks*. OWASP.
17. OWASP Foundation. *OWASP Web Security Testing Guide*. OWASP.
18. OpenSSL Project. *OpenSSL Documentation*. OpenSSL Software Foundation.
19. Wireshark Foundation. *Wireshark User's Guide and Documentation*. Wireshark.
20. Python Software Foundation. *Python 3 Documentation – hashlib and hmac Modules*. Python Software Foundation.

ONE-PAGE INDIVIDUAL REFLECTION

INDIVIDUAL REFLECTION

This assignment gave me a better understanding of how network security works in a real situation. Before doing this assignment, I mainly thought that protecting a network meant encrypting the data. While working on the problem, I understood that encryption alone cannot solve every security issue.

For example, even if the communication is encrypted, an unauthorized person should not be allowed to access the application. This made me understand the importance of authentication and access control. I also learned that authentication and authorization are different. Authentication checks who the user is, while authorization decides what that user can do.

I found the difference between TLS and IPsec interesting. TLS is mainly used to protect application communication such as HTTPS, whereas IPsec can protect communication at the IP level. This helped me understand why organizations may need different security protocols for different types of communication.

The cryptographic implementation also helped me understand hashing and HMAC better. Instead of just learning the definitions, I could see how changing a message can result in a different verification value. This made the concept of data integrity easier to understand.

Another thing I learned was that firewalls, IDS, IPS, and WAF are not the same. A firewall mainly controls network traffic, IDS detects suspicious activity, IPS can block it, and WAF focuses more specifically on web application traffic.

While designing the solution, I understood the importance of using multiple layers of security. For example, if an attacker gets through the firewall, the WAF can still check the request. If the request is allowed, authentication and access control provide another level of protection.

I also realized that adding more security is not always completely free. Encryption, traffic inspection, monitoring, and additional security devices can increase cost and sometimes affect performance. So, a good security design has to find a balance between security, performance, cost, and usability.

Overall, this assignment helped me connect the concepts I studied in Cryptography and Network Security with a practical real-world problem. I learned that protecting a network is not just about keeping hackers out. It is also about making sure that the right person can access the right information, the information is not changed, communication remains private, and suspicious activity is noticed in time.

The biggest lesson I took from this assignment is that good network security works like several locks on a door. Even if one lock fails, the other layers should still protect the system.

